

# 11-XSS - Merry XSSMas

Introduction



Tras la automatización y modernización tecnológica del año pasado, el taller de Papá Noel se renovó. McSkidy cuenta con un portal de mensajes seguro donde puedes contactarla directamente si tienes alguna pregunta o inquietud. Sin embargo, últimamente, los registros han estado llenos de actividad inusual, desde mensajes extraños hasta términos de búsqueda sospechosos. Incluso las cartas de Papá Noel parecen ser scripts o código aleatorio. Tu misión, si decides aceptarla: revisar los registros, descubrir el problema y averiguar quién intenta interferir con McSkidy.

### Objetivos de aprendizaje

- Comprender cómo funciona XSS
- Aprender a prevenir ataques XSS

### Answer the questions below

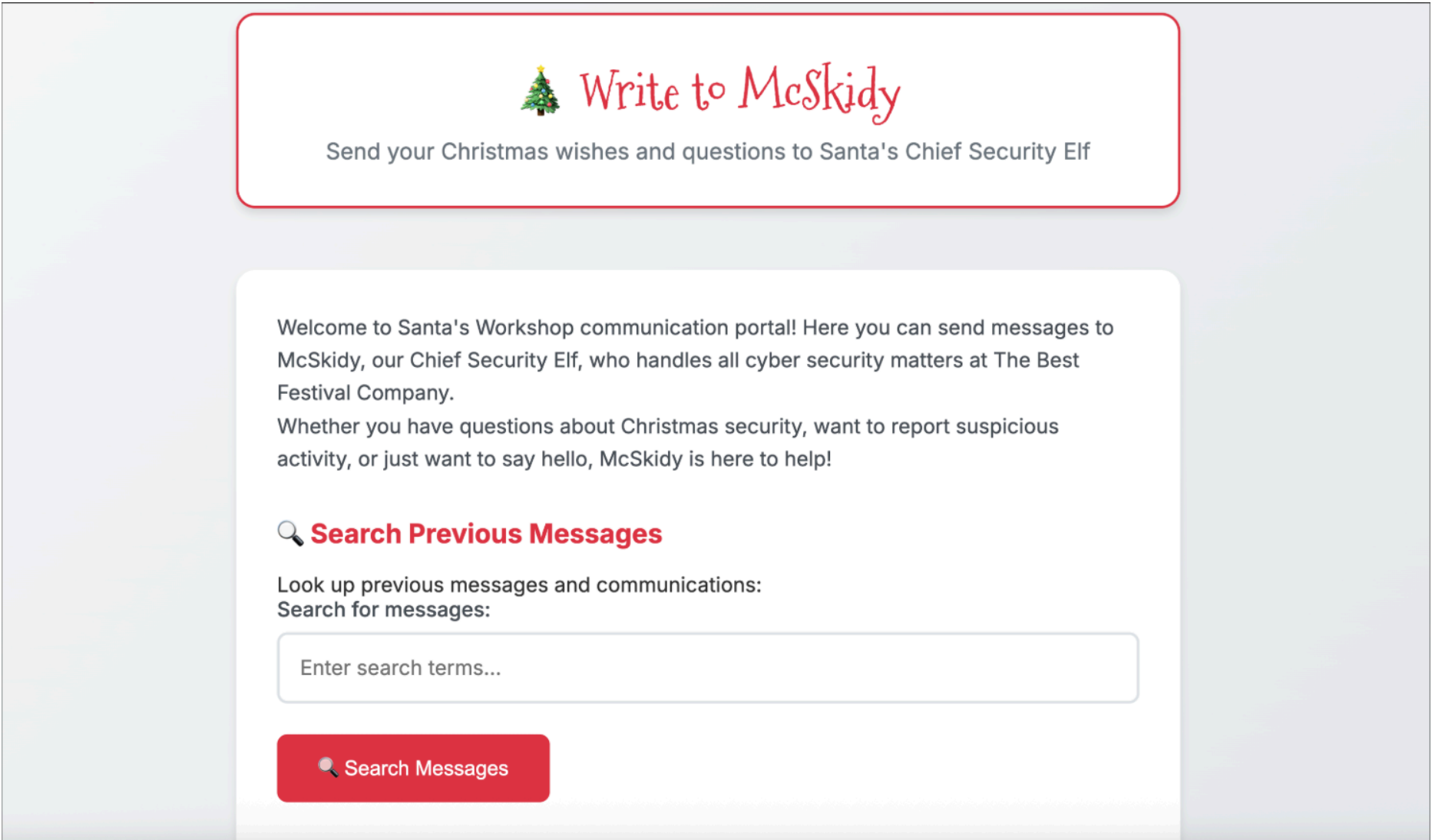
I have successfully started the AttackBox and target machine!

No answer needed

## Leave the Cookies, Take the Payload

### Comprobación del equipo

Para la sala de hoy, usaremos la aplicación web que se encuentra en `http://MACHINE_IP`. Puedes usar el navegador de tu AttackBox para acceder a ella. Verás una página como la que se muestra a continuación:



Repasemos información clave sobre posibles ataques a sitios web como este portal, en concreto sobre secuencias de comandos entre sitios ([XSS](#)).

XSS es una vulnerabilidad en aplicaciones web que permite a los atacantes (o conejitos malvados) inyectar código malicioso (normalmente JavaScript) en campos de entrada que reflejan el contenido visto por otros usuarios (por ejemplo, un formulario o un comentario en un blog). Cuando una aplicación no valida o elude correctamente la entrada del usuario, esta puede interpretarse como código en lugar de texto inofensivo. Esto genera código malicioso que puede robar credenciales, desfigurar páginas o suplantar la identidad de los usuarios. Según el resultado, existen varios tipos de XSS. En la tarea de hoy, nos centraremos en el XSS reflejado y el XSS almacenado.

### XSS reflejado

Se observan variantes reflejadas cuando la inyección se proyecta inmediatamente en una respuesta. Imagine una función de búsqueda de juguetes en una tienda online de juguetes: la búsqueda se realiza mediante:

https://trygiftme.thm/search?term=gift

Pero imagina que le envías esto a tu amigo que está buscando un regalo para su sobrino (por favor, no lo hagas):

https://trygiftme.thm/search?term=<script>alert( atob("VEhNe0V2aWxfQnVubnI9") )</script>

Si tu amigo hace clic en el enlace, se ejecutará el código.

### Impacto

Podrías actuar, ver o modificar información que tu amigo o cualquier usuario podría hacer, ver o acceder. Generalmente se explota mediante phishing para engañar a los usuarios para que hagan clic en un enlace con código malicioso inyectado.

## XSS almacenado

Un ataque de XSS almacenado ocurre cuando se guarda un script malicioso en el servidor y se carga para cada usuario que visita la página afectada. A diferencia del XSS reflejado, que se dirige a víctimas individuales, el XSS almacenado se convierte en un ataque de "configurar y olvidar": cualquiera que cargue la página ejecuta el script del atacante.

Para entender cómo funciona esto, usemos el ejemplo de un blog simple donde los usuarios pueden enviar comentarios que se muestran debajo de cada publicación.

### Envío de comentarios normal

```
POST /post/comment HTTP/1.1
Host: tgm.review-your-gifts.thm

postId=3
name=Tony Baritone
email=tony@normal-person-i-swear.net
comment=This gift set my carpet on fire but my kid loved it!
```

El servidor almacena esta información y la muestra cada vez que alguien visita esa entrada del blog.

### Envío de comentarios maliciosos (ejemplo de XSS almacenado)

Si la aplicación no depura ni filtra la entrada, un atacante puede enviar JavaScript en lugar de un comentario:

```
POST /post/comment HTTP/1.1
Host: tgm.review-your-gifts.thm

postId=3
name=Tony Baritone
email=tony@normal-person-i-swear.net
comment=<script>alert(atob("VEhNe0V2aWxfU3RvcnVhX0VnZ30="))</script> + "This gift set my carpet on fire but my kid loved it!"
```

Dado que el comentario se guarda en la base de datos, cada usuario que abra la entrada del blog activará automáticamente el script. Esto permite al atacante ejecutar código como si fuera la víctima para realizar acciones maliciosas como:

- Robar cookies de sesión
- Activar ventanas emergentes de inicio de sesión falsas
- Deformar la página

## Protección contra XSS

Cada servicio es diferente y requiere un diseño y un plan de implementación seguros y bien pensados, pero las prácticas clave que puede implementar son:

- **Desactivar los renderizados peligrosos:** En lugar de usar la propiedad `innerHTML` , que permite inyectar cualquier contenido directamente en HTML, use la propiedad `textContent` , que trata la entrada como texto y la analiza para HTML.
- **Hacer que las cookies sean inaccesibles para JS:** Configure las cookies de sesión con los atributos [HttpOnly](#), [Secure](#) y [SameSite](#) para reducir el impacto de los ataques XSS.
- **Sanear la entrada/salida y codificar:** En algunas situaciones, las aplicaciones pueden necesitar aceptar una entrada HTML limitada, por ejemplo, para permitir a los usuarios incluir enlaces seguros o formato básico. Sin embargo, es fundamental depurar y codificar todos los datos proporcionados por el usuario para evitar vulnerabilidades de seguridad. La depuración y codificación elimina o escapa cualquier elemento que pueda interpretarse como código ejecutable, como scripts, controladores de eventos o URL de JavaScript, a la vez que preserva un formato seguro.

Para explotar vulnerabilidades XSS, necesitamos algún tipo de campo de entrada para inyectar código. Hay una sección de búsqueda; comencemos por ahí.

### Explotación de XSS reflejado

Para explotar XSS reflejado, podemos usar cargas útiles de prueba para comprobar si la aplicación ejecuta el código inyectado. Si desea probar cargas útiles más avanzadas, existen [cheat sheets](#) en línea que puede usar para crearlas. Por ahora, elegiremos la siguiente carga útil:

<script>alert('Reflected Meow Meow')</script>

Inyecte el código añadiendo la carga útil a la barra de búsqueda y haciendo clic en "Buscar mensajes". Si muestra el texto de alerta, hemos confirmado el XSS reflejado. ¿Qué ocurrió?

- La entrada de búsqueda se refleja directamente en los resultados sin codificación.
- El navegador interpreta su HTML/JavaScript como código ejecutable.
- Apareció un cuadro de alerta que indica la ejecución correcta del XSS.

Puede seguir el comportamiento y cómo el sistema interpreta sus acciones consultando la pestaña "Registros del sistema" en la parte inferior de la página.



# System Logs

## View recent system activity and security events:

```
[2025-10-13 07:50:14] [ACCESS] IP: 127.0.0.1 | Page accessed: /?search=%3Cscript%3Ealert%28%27Testing+Meow+Meow%27%29%3C%2Fscript%3E | User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/90.0.4431.24 Safari/537.36
```

Ahora que hemos confirmado el XSS reflejado, investiguemos si es susceptible al XSS almacenado. Este vector debe ser diferente, ya que debe persistir. Al observar el sitio web, podemos ver que se pueden enviar mensajes, que se almacenan en el servidor para que McSkidy los vea más tarde (a diferencia de las búsquedas, que se almacenan temporalmente en el cliente).

Vaya al formulario de mensajes e introduzca la carga maliciosa que usamos antes (otras también funcionan):

```
<script>alert('Stored Meow Meow')</script>
```

Haga clic en el botón "Enviar mensaje". Dado que los mensajes se almacenan en el servidor, cada vez que acceda al sitio o lo recargue, se mostrará la alerta.

## Wrapping Up

¡Confirmado! El sitio es vulnerable a XSS; no es de extrañar que se hayan detectado cargas útiles inusuales en los registros. El equipo reforzará el sitio para evitar la inyección de código malicioso en el futuro.

### Answer the questions below

Which type of XSS attack requires payloads to be persisted on the backend?

Check

What's the reflected XSS flag?

Respuesta: THM{Evil\_Bunny}

Welcome to Santa's Workshop communication portal! Here you can send messages to McSkidy, our Chief Security Elf, who handles all cyber security matters at The Best Festival Company.

Whether you have questions about Christmas security, want to report suspicious activity, or just want to say hello, McSkidy is here to help!

### Search Previous Messages

Look up previous messages and communications:  
Search for messages:

 Search Messages

 10.81.155.205

Reflected Meow Meow

☐ Don't allow 10.81.155.205 to prompt you again

OK



### Search Previous Messages

Look up previous messages and communications:  
Search for messages:

 Search Messages

#### Search Results:

Flag: THM{Evil\_Bunny}

What's the stored XSS flag?

System Logs

View recent system activity and security events:

[2025-12-11 21:34:00] [ACCESS] IP: 127.0.0.1 | Page accessed: /?search=%3Cscript%3Ealert%28%27Reflected+Meow+Meow%27%29%3C%2Fscript%3E | User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86\_64; rv:131.0) Gecko/20100101 Firefox/131.0

[2025-12-11 21:34:00] [SECURITY] IP: 127.0.0.1 | POTENTIAL XSS DETECTED in search: <script>alert('Reflected Meow Meow')</script> | User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86\_64; rv:131.0) Gecko/20100101 Firefox/131.0

[2025-12-11 21:34:00] [SEARCH] IP: 127.0.0.1 | Search performed: <script>alert('Reflected Meow Meow')</script> | User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86\_64; rv:131.0) Gecko/20100101 Firefox/131.0

[2025-12-11 21:34:00] [ACCESS] IP: 127.0.0.1 | Page accessed: /?search=%3Cscript%3Ealert%28%27Reflected+Meow+Meow%27%29%3C%2Fscript%3E | User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86\_64; rv:131.0) Gecko/20100101 Firefox/131.0

Send a Message to McSkidy

Write your message below and McSkidy will get back to you as soon as possible:  
Your message:

<script>alert('Stored Meow Meow')</script>|

42 characters

Send Message

10.81.155.205

Stored Meow Meow

OK

Recent Messages

Message #1 • 2025-12-11 21:37:03

Flag: THM{Evil\_Stored\_Egg}

System Logs

View recent system activity and security events:

[2025-12-11 21:37:03] [ACCESS] IP: 127.0.0.1 | Page accessed: /?comment\_success=1 | User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86\_64; rv:131.0) Gecko/20100101 Firefox/131.0

[2025-12-11 21:37:03] [SECURITY] IP: 127.0.0.1 | POTENTIAL XSS DETECTED in message: <script>alert('Stored Meow Meow')</script> | User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86\_64; rv:131.0) Gecko/20100101 Firefox/131.0

[2025-12-11 21:37:03] [MESSAGE] IP: 127.0.0.1 | Message posted: <script>alert('Stored Meow Meow')</script> | User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86\_64; rv:131.0) Gecko/20100101 Firefox/131.0

[2025-12-11 21:37:03] [ACCESS] IP: 127.0.0.1 | Page accessed: /?search=%3Cscript%3Ealert%28%27Reflected+Meow+Meow%27%29%3C%2Fscript%3E | User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86\_64; rv:131.0) Gecko/20100101 Firefox/131.0

[2025-12-11 21:34:00] [ACCESS] IP: 127.0.0.1 | Page accessed: /?search=%3Cscript%3Ealert%28%27Reflected+Meow+Meow%27%29%3C%2Fscript%3E | User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86\_64; rv:131.0) Gecko/20100101 Firefox/131.0